cloud security alliance®

Publication

Capabilities-Based Risk Assessment (CBRA) for AI Systems

Establish a Risk Based Approach for Assessing Vendor AI Risk

Table of Contents

Table of Contents....2
Executive Summary....3
Introduction....4
Capabilities-Based Risk Assessment in AI....4
CBRA Risk Elements....5
- System Criticality....5
- AI System Autonomy....6
- Access Permissions....6
- Impact Radius....6
- Scoring Risk....7

CBRA Risk Levels....8
Aligning with AICM....10
- Low Risk – Baseline Controls....11
- Medium Risk – Enhanced Controls....11
- High Risk – Comprehensive Controls....12

Applying CBRA: Industry Examples....13
Conclusion and Recommendations....15
Sources....17

© Copyright 2025, Cloud Security Alliance. All rights reserved.

Executive Summary

Executive Summary: Capabilities-Based Risk Assessment (CBRA)

Capabilities-Based Risk Assessment (CBRA) introduces a modern, structured methodology for evaluating the risks associated with artificial intelligence (AI) systems, particularly in enterprise environments where generative and agentic AI capabilities are rapidly transforming business operations. Unlike traditional AI risk frameworks that assess risk solely by function or output, CBRA considers the systemic and contextual capabilities of AI implementations—providing a more precise, adaptive, and scalable approach to risk management.

CBRA evaluates AI systems based on four multiplicative dimensions: System Criticality, AI Autonomy, Access Permissions, and Blast Radius. Together, these factors define a composite risk score that reflects both the technical power and potential impact of the system. This risk-based stratification enables security, compliance, and governance teams to calibrate controls based on actual risk exposure rather than static categorizations.

Aligned with the Cloud Security Alliance's AI Safety Initiative and mapped to the AI Control Matrix (AICM), CBRA enables enterprises to apply proportional controls to AI deployments. High-risk systems demand rigorous AICM implementation, while lower-risk systems may require fewer governance layers. This dynamic alignment empowers organizations to responsibly scale AI use while maintaining regulatory compliance, data protection, and public trust.

CBRA is designed to evolve alongside the AI systems it measures—supporting continuous monitoring, informed procurement decisions, vendor transparency, and cross-sector benchmarking. As AI becomes more pervasive and autonomous, CBRA provides the enterprise with a forward-looking lens to anticipate, quantify, and manage AI-related risk at the speed of innovation.

© Copyright 2025, Cloud Security Alliance. All rights reserved.

Introduction

Artificial Intelligence (AI) is rapidly being integrated into business operations, decision-making, and critical infrastructure. From healthcare diagnostics to financial trading algorithms, AI-powered systems now drive high-stakes outcomes across sectors. This pervasive adoption brings immense benefits, but it also introduces unique risks ranging from biases in automated decisions to catastrophic failures in autonomous machines. Ensuring these AI systems are safe, trustworthy, and compliant has become a top priority. The Cloud Security Alliance (CSA) has responded with its AI Safety Initiative, a global coalition developing guidance and tools to empower organizations of all sizes to deploy AI solutions that are safe, responsible, and compliant. A key output of this initiative is the AI Controls Matrix (AICM), a comprehensive framework of security and governance controls specifically designed for AI. However, not every AI use case carries the same level of risk.

This white paper introduces a Capabilities-Based Risk Assessment (CBRA) framework for AI, which categorizes AI systems into risk tiers—Low, Medium, and High—based on potential consequences. By aligning these CBRA risk levels with the CSA's AICM controls, organizations can apply the appropriate security and governance measures commensurate with the risks of their AI applications.

The goal is to encourage innovation in AI (including cutting-edge generative and agentic AI) while maintaining rigorous safeguards, especially for high-consequence use cases. In the following sections, we define the CBRA approach, propose three risk levels with example use cases, and map how increasing AICM control requirements should correspond to higher risk tiers. This risk-tiered approach, contributed by CSA's AI Safety working group, aims to serve as a practical blueprint for enterprises and regulators ensuring "safe AI by design" at every level of deployment.

Capabilities-Based Risk Assessment in AI

AI systems do not all pose equal risk. Some AI applications are little more than convenient assistants for human workers, while others autonomously make decisions that could materially affect lives or markets. A static, one-size-fits-all compliance checklist is inefficient because it may under-protect high-stakes AI or over-burden low-stakes projects. Instead, organizations benefit from a Capabilities-Based Risk Assessment (CBRA) approach that evaluates the severity of potential outcomes if an AI system fails or behaves unexpectedly.

CBRA asks: *"What is the worst-case scenario if this AI system makes a mistake or is misused?"* This approach mirrors risk methodologies in other domains. For example, in industrial control system security,

© Copyright 2025, Cloud Security Alliance. All rights reserved.

standards like ISA/IEC 62443 mandate assessing risk from a capabilities-based perspective acknowledges that while threats evolve, the potential impact (consequence) of a failure remains a critical constant. Applying this mindset to AI encourages us to categorize systems by the magnitude of harm they could cause, rather than solely by technical factors or likelihood of failure.

Consequence-based thinking is especially vital for emerging agentic AI systems that act autonomously to pursue goals (often powered by large language models or multi-agent frameworks). Agentic AI "thinks, acts, and evolves," meaning the risk now lies in *how decisions are made and executed without human oversight*. An autonomous AI agent can carry out complex operations and make independent choices, which amplifies the potential consequences of errors or misuse. Agentic AI without proper safeguards may bypass human review and make unauthorized changes in sensitive processes. This challenge underlines why consequences (such as loss of control, safety incidents, or large-scale errors) should drive our risk assessment. By focusing on outcomes, CBRA directly supports the CSA AI Safety Initiative's mission to build "north star" best practices for AI security. It ensures that risk management efforts scale with the gravity of what's at stake for each system.

CBRA Risk Elements

AI systems are no longer point tools at the edge of the stack; they are becoming decision engines that read, write, and act across core systems. To keep pace, CBRA frames vendor exposure with a clear formula that leverages 4 separate elements to help elucidate risk.

Systems Risk = Criticality × Autonomy × Permission × Impact

Using this formula helps prioritize architecture and operating choices that can be defined by assessing impact and leveraging a prescribed set of controls to help reduce risk. Each factor is scored on a five-point anchor scale to reflect how the AI application or service operates. Because autonomy, criticality and other elements may change over time, re-score at onboarding, renewal, and after material changes is necessary. Applied consistently, CBRA lets leaders compare unlike services, prioritize remediation, and compress risk as agentic systems scale through the enterprise.

System Criticality

This captures how much the enterprise depends on the vendor's AI service to operate, comply, or protect itself. Look at what breaks if the service is unavailable, incorrect, or hostile. A low-criticality system supports nonessential analysis or convenience features. A mid-criticality system influences customer experiences, employee productivity, or routine control decisions but has workable fallbacks. A high-criticality system gates revenue, safety, security, or regulatory obligations. For AI vendors, raise the

© Copyright 2025, Cloud Security Alliance. All rights reserved.

score when their model or agent sits in a control plane (identity, data access, payments, code deployment, security policy) or when there is meaningful concentration risk with no realistic substitute. Evidence includes business process maps, revenue attribution, RTO/RPO requirements, and whether incidents would trigger regulatory notifications or material disclosures.

AI System Autonomy

This measures how far the vendor's AI can perceive, decide, and act without human approval. Consider the surface of actions available, not only the presence of "human in the loop." At the low end the system produces recommendations with clear human review and no direct ability to execute changes. In the middle the system can take bounded actions with approvals, rate limits, or policy constraints, and it cannot change its own goals. At the high end the system chains tools, calls external APIs, launches jobs, or spawns agents, adapts behavior across sessions, or self-tunes prompts or policies. Increase the score when the vendor enables multi-agent orchestration, long-lived memory, workflow branching, or cross-system tool use. Decrease it when there are real, enforced guardrails: step-up approvals for sensitive actions, least-privilege tool scopes, typed action schemas, simulation sandboxes, circuit breakers, rollbacks, and complete action logs with tamper-evident storage.

Access Permissions

This reflects the breadth and depth of what the vendor can read, write, execute, or delegate across your environment and data. Inventory identities, scopes, and tokens the vendor uses, then evaluate what those can actually touch. A low score means narrow, read-only access to nonsensitive data through a brokered interface with short-lived credentials and customer-managed keys. A mid score covers targeted write operations or read access to sensitive datasets inside strong segmentation with fine-grained auditability. A high score appears when the vendor can write to production systems, modify policies, move data between trust zones, impersonate users or service accounts, or handle encryption keys. Adjust upward if the vendor trains or tunes on your data, retains content, or co-mingles telemetry in a way that could leak across tenants. Adjust downward when there is reliable support for ephemeral identities, just-in-time privilege elevation, customer-held KMS, private networking, granular token scopes, deterministic data residency, and complete event export to your SIEM.

Impact Radius

This is the maximum plausible harm in one adverse scenario, given the permissions and autonomy you granted and the vendor's technical and organizational isolation. Think in four layers. Data impact asks how much and what kind of data could be exfiltrated or corrupted in a single failure. Functional impact asks which systems could be disabled or degraded, and for how long, including cascading effects through

© Copyright 2025, Cloud Security Alliance. All rights reserved.

automation. Decision impact asks what bad actions the AI could trigger at scale, such as mispricing, fraudulent approvals, or policy drift. Influence impact asks whether the model could poison shared knowledge, models, or agents in ways that persist. A low score means tight tenant isolation, rate limits, per-customer compute and storage isolation, canary rollout, and easy rollback limit any single event. A high score means broad lateral movement is possible, data or policy changes propagate quickly, and rollback is difficult. Consider whether compromise would spread through model supply chains, shared embeddings, or cross-customer fine-tuning, and whether the vendor's own third parties enlarge your exposure.

Scoring Risk

To operationalize CBRA in system assessments, score each element and document the reasoning behind every score. The objective is more than a single total; it is a comparable risk shape you can track over time and use to guide remediation. This keeps evaluations repeatable, auditable, and tied to real controls, while giving you a living baseline as autonomy and integrations grow.

Low = 1	Medium = 2	High = 3

Risk Scoring Scale

Keep notes on the rationale so scores can be audited. Two vendors with the same headline score can have very different risk shapes, so retain the vector.

A tool that suggests content for marketers which represents low risk to the enterprise might be scored like this:

Risk Score	Criticality	Autonomy	Permission	Impact
1	1	1	1	1

While an agent that can rotate IAM policies in production might be scored like this indicating high risk:

Risk Score	Criticality	Autonomy	Permission	Impact
48	3	2	3	3

Because the model is multiplicative, small improvements to autonomy guardrails or permission scopes can materially compress total vendor risk. That creates a risk reduction roadmap: reduce active tool scopes, shorten token lifetimes, force customer-managed keys, require step-up approvals for sensitive actions, enforce hard rate limits, and demand per-tenant isolation with impact tests. Reassess on a schedule

© Copyright 2025, Cloud Security Alliance. All rights reserved.

because autonomy, training modes, and integrations tend to expand over time. Tie renewals and new integrations to re-scoring, require telemetry export that proves the controls are in use, and make circuit breaker drills part of business continuity. This forward-looking discipline keeps the CBRA score honest as AI systems become more agentic and more deeply embedded in your operating fabric.

CBRA Risk Levels

We propose classifying AI vendor and systems into three broad risk levels under the CBRA framework: Low, Medium, and High Risk. This tiered model is conceptually aligned with other AI governance efforts, such as the EU AI Act's categorization of minimal, limited, and high-risk AI systems. The EU framework also defines an "unacceptable risk" category for AI uses that are explicitly prohibited. In our CBRA approach, any use case falling into an "unacceptable" category (e.g., AI violating fundamental rights) should simply not be pursued. The three risk levels distinguish the severity of potential harm or disruption the AI system could cause if it fails, produces incorrect output, or can be exploited maliciously. Below, we detail each level, with illustrative use cases of generative and agentic AI to highlight the differences.

Low-risk AI applications are those where failures or incorrect outputs would have minimal consequences. These systems might automate or assist with non-critical tasks, where errors cause at most minor inconvenience or easily reversible effects. Typically, low-risk AI operates under human supervision or in domains of low sensitivity. An example is a generative AI tool used to draft marketing content or summarize public news articles for internal reports. If the AI produces a subpar paragraph or a factual error, the impact is trivial. A human reviewer can catch and correct it, and no lasting harm is done. Another example is a code-generation assistant for software developers working on non-safety-critical software; if the suggested code is buggy, developers will review and test it as part of their normal workflow. Even some agentic AI can be low-risk, if tightly sandboxed. For instance, an AI agent tasked with organizing your email inbox. It autonomously sorts messages and drafts replies, but any major mistake (like an incorrect email draft) is likely to be noticed by the user and has limited fallout.

Low-risk does not mean *no* risk; even these AI systems warrant basic precautions. For instance, a generative AI writing tool should still avoid leaking any sensitive data or intellectual property. Indeed, "shadow AI" use of even simple tools can introduce problems if employees unwittingly paste confidential information into public models. But overall, the potential damage from low-risk AI is contained and non-life-threatening. In highly regulated sectors, very few AI use cases will fall into this category, except perhaps for experimental or internal tools that do not involve sensitive data or critical decisions. A regulated company might designate something like an AI that formats routine reports as low risk. The key criterion is that if the AI system outputs incorrect information or behaves poorly, the repercussions are negligible and easily manageable.

Medium-risk AI covers a broad middle ground of applications where AI plays a significant role and errors could cause harm or compliance issues, but are unlikely to be catastrophic or irreversible. These AI

© Copyright 2025, Cloud Security Alliance. All rights reserved.

systems may influence essential decisions or handle sensitive data, yet still operate with human oversight or within bounds that limit worst-case damage. Many enterprise AI use cases, such as those in business processes, customer service, or decision support, fall under this category. For example, consider a generative AI integrated into an e-commerce website's customer support chat. It autonomously answers user queries and even issues refunds or discounts based on preset rules. If the bot makes a mistake, the company might lose money or need to placate an unhappy customer. In this situation, the issue can be remedied and won't imperil the business. In another scenario, an AI tool that screens job applicant résumés to help HR narrow candidates. If not carefully managed, such a tool could inadvertently introduce bias (e.g., favoring or disfavoring candidates of a certain demographic), leading to unfair hiring outcomes and potential discrimination lawsuits. There is a serious risk (both legal and ethical), yet with proper oversight (e.g., HR reviewing AI-recommended rejections) the organization can identify and correct these issues before irreparable harm is done. The consequence of failure is significant (harm to individuals' opportunities and company liability) but not life-and-death.

Agentic AI systems can also be medium risk when their domain is constrained. Imagine an autonomous AI agent managing inventory and restocking for a retail company. It may negotiate prices with suppliers and trigger orders independently. If it fails (perhaps due to over-ordering a product or choosing a supplier that goes bankrupt), the company could lose money or face stock issues, but human managers can step in to correct the course. There is no immediate threat to human safety, though financial losses or operational disruptions are possible. Highly regulated industries, such as finance and healthcare, may classify certain assistive AI as medium risk. For instance, an AI that suggests investment portfolio changes to a financial advisor (where the advisor must approve the changes), or a diagnostic aid in a hospital that flags potential illnesses for a doctor to review. Errors in these cases could lead to monetary loss or a missed diagnosis, which are serious but ideally buffered by human review. Medium-risk AI requires diligent controls because the consequences, although not dire, are non-trivial: they can harm individuals (e.g., through biased decisions) or lead to compliance breaches.

High-risk AI encompasses any AI application where a failure or malicious exploitation could have severe, even catastrophic consequences. These are the systems operating in high-stakes contexts often involving the safety of humans, critical infrastructure, significant financial or societal impact, or stringent regulatory obligations. In high-risk scenarios, an AI mistake can directly lead to injury, loss of life, massive financial devastation, or violation of fundamental rights. By definition, these systems are also typically subject to heavy regulatory scrutiny. Examples of high-risk AI are abundant as organizations push the boundaries of automation. Consider AI in healthcare: an AI diagnostic system that recommends treatments or medication dosing. If it produces an incorrect recommendation and clinicians trust it blindly, patients' health may be jeopardized. In one notable case, an AI medical tool gave unsafe cancer treatment advice during trials illustrating how *unvetted AI decisions could harm patients* if deployed without safeguards (a risk so high that such a system would not likely gain approval without rigorous validation).

Another example is autonomous driving AI. A self-driving car is a quintessential high-risk agentic AI; a flaw in its object detection or decision logic can cause accidents and loss of life. It is not a hypothetical scenario. In 2018, a self-driving test vehicle operating in autonomous mode struck and killed a pedestrian,

© Copyright 2025, Cloud Security Alliance. All rights reserved.

marking the first such fatality on record. The incident underscored the real stakes of an AI controlling kinetic processes in the physical world. Similarly, an AI-powered system managing an electrical grid or a chemical plant could, if compromised or errant, lead to cascading disasters.

Beyond safety, financial and governance impacts can also define high risk. An AI trading algorithm at a major bank that executes high-volume transactions could wreak havoc on markets or a firm's balance sheet if it behaves unpredictably. Likewise, a generative AI system deployed to moderate content on a large social media platform automatically might be considered high risk because mistakes at scale could influence public discourse or lead to legal violations (e.g., failure to filter violent content or erroneously suppressing legitimate speech). In all these cases, the potential harm is widespread and acute – hence high-risk AI must meet the most stringent requirements for validation, oversight, and security.

It's worth noting that many AI uses in *"highly regulated industries"* (finance, healthcare, automotive, aerospace, etc.) will gravitate to this category, because regulation often targets applications where the public stakes are high. For example, the EU's draft AI Act explicitly lists AI systems in medical devices, credit scoring, employment decisions, and critical infrastructure control as high-risk, necessitating compliance with strict requirements. The CBRA framework aligns with this philosophy by flagging such use cases as high risk and demanding comprehensive controls before deployment.

Aligning with AICM

The Cloud Security Alliance's AI Controls Matrix (AICM) provides an extensive catalog of security and governance controls for AI systems, building upon CSA's earlier Cloud Controls Matrix (CCM) and extending it to address AI-specific challenges such as model integrity, data quality, and transparency. The current AICM (v1.0) encompasses 18 security domains, ranging from traditional areas such as Identity and Access Management and Incident Response to AI-centric domains like Model Security, and includes more than 240 control objectives in total. Each control is designed as a measurable safeguard to mitigate risks in AI development or deployment, including threats like model manipulation, data poisoning, model theft, and insecure AI supply chains. Just as the CCM is mapped to multiple global frameworks, the AICM is designed for interoperability and alignment with existing standards and regulations. At launch, it includes mappings to BSI AIC4 and NIST AI 600-1, and now that the framework has successfully completed peer review, mappings to ISO standards and the EU AI Act will soon be announced. These mappings complement existing alignments to widely adopted frameworks such as ISO/IEC 27001, NIST AI RMF, and ISO/IEC 42001, underscoring that the AICM is intended to unify best practices for trustworthy AI. Importantly, its controls address both traditional IT and cloud security—since AI systems rely on underlying software and cloud infrastructure—and AI-specific measures such as bias monitoring, adversarial testing, and model provenance tracking.

However, not every AI project requires the full breadth of 240+ controls to be applied with equal rigor. This is where CBRA risk levels provide a valuable filter. By aligning AICM controls to the Low, Medium, and

© Copyright 2025, Cloud Security Alliance. All rights reserved.

High risk tiers, organizations can adopt a graduated approach: *the higher the risk, the more AICM controls (and the more stringent their implementation) should be in place*. Such tailoring is analogous to how information security frameworks adjust controls based on system criticality. (For instance, U.S. government cloud systems under FedRAMP have baseline control sets for Low, Moderate, and High impact levels, with high-impact systems requiring the most comprehensive controls and audits.) In the AI context, a low-risk system might warrant only a core subset of the AICM as mandatory, whereas a high-risk system would need to comply with nearly all relevant controls in depth. Below, we outline how an organization could align controls to each CBRA level:

Low Risk – Baseline Controls

For low-risk AI applications, the emphasis is on fundamental security and governance hygiene. At a minimum, controls that protect the confidentiality and integrity of data, as well as ensure basic functionality, should be in place. For example, AICM's domain of Governance, Risk & Compliance (GRC) includes defining an AI governance policy and risk management process, which even low-risk projects should have (albeit scaled to their context). Basic data security and privacy controls from AICM must also be applied, ensuring that even a simple generative AI tool does not inadvertently leak sensitive information or violate privacy laws. Identity and access controls (restricting who can use or modify the AI system) are another baseline captured in AICM's Identity & Access Management (IAM) domain.

Low-risk AI should meet the subset of AICM controls that correspond to standard cloud application security (since any AI system still runs on software and cloud services that need protection) and minimal AI-specific guardrails. These may include having an acceptable use policy for AI (preventing the aforementioned shadow AI issues), performing rudimentary testing on the AI outputs for reasonableness, and ensuring there is human awareness/oversight of the AI's operation. Notably, the Audit & Assurance domain in AICM (e.g., A&A-01 policy and A&A-02, which require independent assessments) may be applied more lightly e.g., a periodic management review rather than formal audits for a trivial tool. Low-risk systems can leverage the AICM as a checklist to ensure that no noticeable security gap is overlooked; however, the effort and rigor correspond to the lower potential impact. Organizations may choose to fast track approval of systems with low risk scores to help smooth AI adoption.

Medium Risk – Enhanced Controls

Medium-risk AI deployments should implement a broader set of AICM controls, including many of the AI-specific measures, because the stakes are higher. In addition to all baseline controls, medium-risk systems call for a stronger emphasis on Validation, Monitoring, and Transparency. For instance, AICM's Model Security domain would be highly relevant, covering controls such as adversarial robustness testing, dataset quality checks, and ensuring model updates follow change control procedures. Suppose an AI system is making decisions that affect people (such as hiring or lending). In that case, controls related to

© Copyright 2025, Cloud Security Alliance. All rights reserved.

Bias and Fairness (possibly captured under GRC or data management domains) become essential including regular bias audits and documentation of model fairness. Logging and Monitoring controls from AICM need to be well-established so that the AI's behavior is recorded and can be audited or traced (this mitigates the "audit invisibility" risk of agentic AI, where decisions could otherwise be a black box). Medium risk also implies the need for more robust incident response plans specific to AI issues. AICM's Security Incident Management domain likely addresses having procedures to handle incidents like a model output causing a compliance violation or detecting that an AI was fed poisonous data. For generative AI systems serving externally (e.g., a customer chatbot), Content controls (to prevent toxic or sensitive outputs) would align with AICM controls on responsible AI usage.

In regulated contexts, many medium-risk AI controls overlap with compliance obligations; for example, a finance company using AI for client interactions will need to follow AICM's privacy controls to ensure GDPR or GLBA compliance when personal data is involved. Essentially, a medium-risk AI system should comply with *most* AICM controls across governance, technical security, data management, and the AI lifecycle. The organization may not yet require extreme measures such as a dedicated AI safety committee or third-party red-team exercises at the frequency of high-risk systems, but it should have thorough internal checks. It is at this tier that external validation becomes valuable (e.g., voluntary audits or assessments against frameworks like the NIST AI Risk Management Framework or even CSA's forthcoming AI Security certification) to ensure nothing critical is missed. By implementing enhanced controls from the AICM, organizations reduce the chance that medium-impact risks (like a biased decision or moderate financial loss) escalate into something bigger or go undetected.

High Risk – Comprehensive Controls

High-risk AI systems require the full spectrum of controls prescribed by the AICM (and other standards). Here, nothing can be left to chance, because the potential consequences involve human lives, critical infrastructure, or major legal and financial repercussions. All relevant controls from the 18 AICM domains should be considered mandatory for high-risk deployments. For instance, Governance must be at its strongest: AICM's GRC controls call for a formal AI risk governance program with executive oversight, clear accountability (e.g., an AI risk officer or committee), and mapping of regulatory requirements. These are indispensable for high-risk uses. Independent audits and assessments (AICM A&A-02) should be conducted at least annually, if not more often, to verify adherence to policies.

Model Security controls must be exhaustive: rigorous adversarial testing, strict change management for model updates, encryption and access control for model artifacts (to prevent theft or tampering), and continuous monitoring for concept drift or performance degradation. In a high-risk AI, even a slight model error can have outsized effects, so continuous evaluation and red-teaming are necessary aligning with AICM controls on validation and threat vulnerability management. The CSA AICM threat taxonomy explicitly lists threats such as data poisoning, model malfunction, insecure plugins, and denial-of-service attacks; high-risk systems require contingency and mitigation plans for each of these. For example, Supply Chain controls (AICM's STA domain) ensure that if the AI model or data comes from third parties,

© Copyright 2025, Cloud Security Alliance. All rights reserved.

those are vetted and secured which is crucial if, say, a hospital is using an AI from a vendor for diagnosis (one must ensure the vendor follows strict quality controls).

Business Continuity and Resilience controls also come to the forefront: a high-risk AI should have fail-safes or human takeover capability. Autonomous vehicles need mechanisms to hand control to a human or safely stop if the AI encounters a situation it doesn't understand. Correspondingly, AICM's Business Continuity & Operational Resilience domain would apply, requiring disaster recovery plans, backup systems, or fallback modes for AI services that could fail. Additionally, transparency and explainability become non-negotiable at high risk. Suppose an AI makes a critical decision (such as rejecting a loan or altering a treatment plan). In that case, AICM controls should ensure that the decision-making process is documented and explainable, and that this is enforced.

High-risk agentic AI should also implement strong deterministic constraints on actions and "kill switches" or override mechanisms. These are features that likely map to multiple AICM domains (such as IAM for privileged action control, or application security for implementing fail-safe logic). In summary, a high-risk AI system, before going live, should be able to withstand comprehensive scrutiny, including internal risk reviews, external audits, compliance checks, and adversarial tests. It must also have governance structures in place to continuously monitor its performance. This mirrors how high-criticality systems are treated in other fields (for instance, aircraft AI systems go through intensive certification). The AICM provides the checklist of controls; CBRA tells us we need to check them all for high risk. The outcome of such diligence is to minimize the chance of disasters, because when an AI has the potential to cause a tragedy or a systemic crisis, every possible safeguard should be in place to prevent that outcome.

Applying CBRA: Industry Examples

Adopting the CBRA framework means embedding risk-level assessment into the AI development and deployment lifecycle. Organizations should begin by evaluating each planned AI use case for its potential consequences, classifying it into low, medium, or high risk, and then applying controls by the aligned AICM guidance for that tier. This process is not one-time; it should be revisited as systems evolve or new information emerges (for example, an AI might start in a constrained pilot as "low risk" but later be scaled up to critical operations "high risk", warranting reclassification). Crucially, CBRA is not only about technology controls but also organizational governance. A CSA working group could, for instance, recommend that companies establish an AI Risk Review Board to approve all new AI deployments, assigning each a risk level and mandating controls accordingly. Highly regulated industries are already familiar with analogous processes (e.g., banks classify new products by risk and impose controls, hospitals do risk assessments for new clinical tools). CBRA simply tailors this to the AI context, with the AICM as the library of controls to draw from.

To illustrate, imagine a financial services firm implementing two AI systems: one is a generative AI chatbot for customer service (answering general queries), and the other is an agentic AI for algorithmic trading.

© Copyright 2025, Cloud Security Alliance. All rights reserved.

The chatbot is assessed as medium risk because mistakes could lead to customer dissatisfaction or minor compliance issues if it provides incorrect policy details, but it won't compromise the business. The trading AI, on the other hand, could cause multi-million dollar losses in seconds if it goes awry is considered high risk.

Using CBRA, the firm applies a stringent set of AICM controls to the trading AI: e.g., intensive pre-deployment testing for edge cases, real-time monitoring with kill-switches if certain thresholds are breached, audit logs of every decision it makes, and even limiting its autonomy (perhaps it cannot execute trades above a certain amount without human sign-off). They also ensure compliance with financial regulations by mapping AICM controls to requirements like SEC or ESMA guidelines for algorithmic trading. For the chatbot, the firm focuses on core controls, including data privacy (to prevent the disclosure of customer data), content moderation to prevent inappropriate statements, and logging its conversations for later review. They might skip more heavyweight controls (no need for a full third-party audit or complex failover systems for the chatbot during its pilot phase). The CBRA process thus optimizes control application making heavier investments where the risk is truly high, and lighter governance where the risk is low, all while maintaining a baseline of security everywhere.

Consider a healthcare scenario: an extensive hospital network uses an AI system to analyze radiology images and flag potential tumors for doctors (a diagnostic assistive tool). This would likely be Medium risk, since doctors still make final diagnoses, but the tool's suggestions could influence care. A CBRA-informed approach would have the hospital implement many AICM controls: robust testing of the model's accuracy across diverse patient demographics (to avoid bias or misses), an approval workflow where any AI-flagged findings validated by radiologists (human oversight control), strict patient data privacy safeguards (HIPAA compliance mapped via AICM's privacy controls), and continuous performance monitoring in case the model's accuracy drifts over time. Now, if the hospital later considers using an autonomous AI surgeon robot in the operating room (agentic AI performing specific procedures), that would be high risk meaning *every* safeguard must be in place before such a system touches a patient: extensive validation in simulated and supervised settings, certification to medical device standards, real-time human override capabilities, fail-safe modes (if the AI detects anomaly or uncertainty it pauses and alerts a surgeon), physical security to prevent hacking of the robot, etc. Many of these map to AICM's controls in areas like Change Management, Incident Response, Model Security, and Business Continuity (planning for what if the AI fails mid-surgery). The hospital's CBRA would dictate that an autonomous surgical AI should not be deployed without demonstrating compliance with essentially the full AICM and any additional domain-specific regulations.

Cross-industry, CBRA can guide innovation by allowing lower-risk AI experiments to proceed with agility (applying just the necessary controls so as not to stifle progress), while slowing down and thoroughly vetting the high-risk projects that need it. For example, a manufacturing company might have a Low-risk AI that optimizes equipment maintenance schedules (if it errs, a machine's maintenance is delayed slightly low impact), versus a High-risk AI controlling the assembly line robots in real-time (an error could damage expensive equipment or injure workers high impact). The maintenance AI might just follow basic AICM controls for data integrity and have a human review any schedules it produces. The assembly line AI would

© Copyright 2025, Cloud Security Alliance. All rights reserved.

undergo formal hazard analysis, safety certifications, and incorporate physical fail-safes, in addition to all the software security controls from AICM, given the direct danger it could pose. Notably, regulators and auditors are increasingly expecting such risk differentiation. They do not want companies to apply a superficial checklist to a super-critical AI and call it "secure." Regulators and auditors expect rigorous controls where due. Conversely, they encourage experimental AI in non-critical settings as long as basic governance is observed, so that beneficial AI adoption isn't chilled by compliance overkill. The CBRA framework, aligned with the CSA's AICM, provides a transparent and standardized approach to meeting these expectations. An organization can document: *"We categorized this AI as Medium risk because it affects customer data and decisions, but with human oversight; therefore, we implemented 150 of the AICM controls, including all privacy, monitoring, and bias controls. That provides reasonable mitigation for the identified risks. For that other AI, which is High risk, we implemented all 240+ AICM controls and additional layers of review."* Such an approach could be presented to regulators, clients, or insurers to demonstrate a credible AI risk management program.

Conclusion and Recommendations

As AI technologies evolve from passive assistants to autonomous decision-makers, organizations must evolve their risk management accordingly. The Capabilities-Based Risk Assessment (CBRA) framework for AI proposed in this paper offers a structured method to do so, by aligning the required rigor of controls with the potential impact of an AI system's failure. In partnership with the Cloud Security Alliance's AI Safety Initiative and using the AI Controls Matrix (AICM) as the foundation, CBRA enables a practical and scalable approach to AI governance. Low-risk AI systems can be fast-tracked with lighter governance that nonetheless covers essential security and privacy, ensuring even experimental projects are not a free-for-all. Medium-risk systems receive a balanced set of controls to manage meaningful (but containable) risks, striking a harmony between innovation and oversight. High-risk AI, which stands to yield great rewards but also could inflict significant harm, is restrained by a comprehensive safety net of controls reflecting the principle that the higher the stakes, the tighter the guardrails. This tiered strategy aligns with what forward-thinking regulators are advocating for: the EU's risk-based AI regulation approach is a notable example of prioritizing stringent compliance for high-risk uses and minimal interference for low-risk ones. Our CBRA model translates that philosophy into actionable steps for organizations and ties it to an industry-vetted control library (the AICM).

For practitioners and AI working groups (such as those in CSA) looking to implement CBRA, we recommend the following: First, embed risk level assessment early in your AI project lifecycle (e.g., during project kickoff or design review) and explicitly discuss worst-case outcomes and classify the project's risk. Ask the tricky question highlighted in secure agentic AI guidance: *"Is the use of AI here appropriate, and what's the worst that can happen if it fails?"*. This frank assessment grounds the team in reality.

Second, use the AICM (or a similar control framework) to derive a control plan proportional to that risk. Treat the AICM's 18 domains as a menu: low-risk projects might select baseline items from each domain,

© Copyright 2025, Cloud Security Alliance. All rights reserved.

while high-risk ones will need to complete the entire course. Document the rationale for any control that is *not* applied to a high- or medium-risk system, and be prepared to justify how other mitigations cover that area. This creates accountability and can be reviewed by auditors or stakeholders.

Third, incorporate continuous monitoring and periodic re-evaluation. Risk levels can change due to external factors (a new threat technique emerges, or a regulatory change can effectively elevate a system from medium to high risk). CBRA should be a living process, revisited as part of AI system maintenance. The CSA AI Safety Initiative's emphasis on *continuous improvement* and *community-driven best practices* means that new controls or techniques will arise to address AI risks; a CBRA-oriented organization will integrate those according to the risk tier of each system, ensuring agility.

Finally, we suggest that industry coalitions and standards bodies consider formally adopting risk-tiered control guidance. CSA's forthcoming programs (such as the STAR for AI assurance certification) could incorporate CBRA principles by defining level-specific control requirements for certification. This would mirror how cloud providers achieve different STAR levels or how FedRAMP certifies at different impact levels. By doing so, the ecosystem creates a common language: when someone says "this AI system is High risk and meets CBRA High controls," it signals a high degree of rigor and trust, whereas "Low risk, baseline controls" signals a lightweight, safe use case. Such clarity can help build public trust in AI. People and regulators alike can be assured that high-consequence AI is not being deployed carelessly, and low-consequence AI is not being needlessly hampered.

CBRA aligned with AICM offers a blueprint for risk-informed AI governance. It enables us to harness the transformative power of both generative and agentic AI across industries, while maintaining a strong focus on safety and ethics. As AI continues to advance, it is our collective responsibility – in industry working groups like CSAs, in enterprise leadership, and in policy circles – to ensure that our risk management evolves in lockstep. By focusing on consequences and proportionate controls, we can chart a path where AI innovation flourishes under the guard of robust security and trust. This whitepaper, as a CSA working group contribution, aims to stimulate further discussion and refinement of risk-tiered approaches, ultimately contributing to a safer AI-enabled future for all.

© Copyright 2025, Cloud Security Alliance. All rights reserved.

Sources

1. CSA AI Safety Initiative – *Overview of goals and research outputs*

2. CSA AI Controls Matrix (AICM) – *Structure and scope of controls (18 domains, 240+ controls) and AI-specific threats addressed*

3. Medium (M. Sajid Khan, July 2025) – *Discussion of AI risk frameworks and the need for tailored controls; notes that AI is embedded in critical systems like healthcare/finance where failures have real consequences*

4. CSA Blog "AI Gone Wild: Shadow AI" – *Illustrative risk example of biased AI resume screening tool causing discrimination concerns*

5. LinkedIn (B.Z. Zinga, May 2025) – *Agentic AI risks and mitigation (loss of control, need for overrides, "worst-case scenario if it fails" assessment)*

6. EU AI Act Summary – *Defines AI risk tiers (minimal, limited, high, unacceptable) with escalating obligations, aligning with the risk-based approach in this paper*

7. Wikipedia (Elaine Herzberg case) – *First recorded pedestrian fatality from a self-driving car, exemplifying high-risk AI consequences*

8. Industrial Cyber (Oct 2023) – *Consequence-based risk perspective in critical infrastructure security, analogous to CBRA approach for AI*

© Copyright 2025, Cloud Security Alliance. All rights reserved.